Entry Information

ID:
AML.CS0044

Type:
Case-Study

Name:
LAMEHUG: Malware Leveraging Dynamic AI-Generated Commands

URL:
https://atlas.mitre.org/studies/AML.CS0044/

Incident Date:
2025-06-03

Target:
Ukraine’s security and defense sector

Actor:
APT28

Description

In July 2025, Ukrainian authorities reported the emergence of LAMEHUG, a new AI-powered malware attributed to the Russian state-backed threat actor [APT28](https://attack.mitre.org/groups/G0007/) (also tracked as Forest Blizzard or UAC-0001). LAMEHUG uses a large language model (LLM) to dynamically generate commands on the infected hosts.

The campaign began with a phishing attack leveraging a compromised government email account to deliver a malicious ZIP archive disguised as Appendix.pdf.zip. The archive contained the LAMEHUG malware, a Python-based executable, packed with PyInstaller. When executed, the malware, makes calls to an LLM endpoint to generate malicious from natural language prompts. Dynamically generated commands may make the malware harder to detect. LAMEHUG was configured to collect files from the local system and exfiltrate them.

Attack Procedure:
[AML.T0012] Valid Accounts: APT28 gained access to a compromised official email account.
[AML.T0052] Phishing: APT28 sent a phishing email from the compromised account with an attachment containing malware.
[AML.T0073] Impersonation: The email impersonated a government ministry representative.
[AML.T0074] Masquerading: The attachment was called “Appendix.pdf.zip” which could confuse the recipient into thinking it was a legitimate PDF file.
[AML.T0011] User Execution: The attachment contained an executable file with a .pif extension, created using PyInstaller from Python source code which CERT-UA classified it as LAMEHUG malware. Files with the .pif extension are executable on Windows.
[AML.T0102] Generate Malicious Commands: The LAMEHUG malware abused the Qwen 2.5 Coder 32B Instruct model Hugging Face API to generate malicious commands from natural language prompts.
[AML.T0037] Data from Local System: The LAMEHUG malware used the AI generated commands to collect system information (saved to `%PROGRAMDATA%\info\info.txt`) and recursively searched Documents, Desktop, and Downloads to stage files for exfiltration.

[AML.T0025] Exfiltration via Cyber Means: The LAMEHUG malware exfiltrated collected data to attacker controlled servers via SFTP or HTTP POST requests.

References

- UAC-0001 cyberattacks on the security and defense sector using the LAMEHUG software tool, which uses LLM (large language model) (CERT-UA#16039) — https://cert.gov.ua/article/6284730

- APT28's New Arsenal: LAMEHUG, the First AI-Powered Malware — https://logpoint.com/en/blog/apt28s-new-arsenal-lamehug-the-first-ai-powered-malware

- LameHug malware uses AI LLM to craft Windows data-theft commands in real-time — https://www.bleepingcomputer.com/news/security/lamehug-malware-uses-ai-llm-to-craft-windows-data-theft-commands-in-real-time/